Fiche de défense : VETO

Secure Horizons, track 1 « Fintech Security: Guardians of Value ». État du dépôt au 11 octobre 2026. Mesures du détecteur et cas manqués : fiche-defense-mesures.md. Nouvelle campagne trimestrielle : pitch-chiffres.pdf.

Scénario de menace

Le scénario simule des agents IA soumis à des factures piégées, à des demandes rejouées et à des clés volées. Dans les scènes du coffre, le client signataire est un bouchon déterministe : aucun modèle n'est trompé en direct. La scène de la facture inconnue transmet une référence fixée par le script, puis le contrat la refuse. Le coffre limite les effets d'une demande hostile aux références, montants et bénéficiaires admis ; il ne vérifie pas qu'une facture admise est vraie.

Fonctions NIST CSF 2.0 couvertes

Fonction	Ce que fait le projet	Où
Govern (`GV.RR`)	Cinq rôles séparés sur le coffre : propriétaire, admission, relais, approbateur, gardien. Aucune action automatique ne déplace de fonds	**`src/ArgentVault.sol`**, **`playbook.md`**
Identify (`ID.AM`)	Registre des agents et de leur mandat sur la chaîne, doublé d'un jeton court par agent à la porte d'entrée	**`src/ArgentVault.sol`**, **`gateway/src/tokens.ts`**
Protect (`PR.AA`, `PR.DS`)	Liste d'émetteurs admis du L1 : le nœud refuse tout autre émetteur. Signature EIP-712 liée à la chaîne et au coffre, demande consommée une seule fois, validation humaine au-dessus du seuil	**`infra/l1/`**, **`docs-jury/preuves/scene-aws.md`**
Detect (`DE.CM`, `DE.AE`)	Détecteur à règles sur chaque demande (score, codes raison). Décision 0 du contrat lue dans l'événement **`Decision`**. Comité de trois vérificateurs LLM, non relié au coffre	**`gateway/src/detector.ts`**, **`docs-jury/verificateurs-llm.md`**
Respond (`RS.MA`, `RS.MI`, `RS.CO`)	Quarantaine, pause de l'agent, alerte, rapport d'incident prérempli, journal chaîné vérifiable par script	**`response/src/engine.ts`**, **`playbook.md`**
Recover (`RC.RP`)	Partiel : une pause ne se lève que par une décision humaine journalisée. Aucun plan de reprise au-delà	**`response/`**

Techniques et risques visés

Référentiel	Éléments visés
MITRE ATLAS	AML.T0051 LLM Prompt Injection : .001 Indirect (la facture piégée), .000 Direct. AML.T0053 AI Agent Tool Invocation
MITRE ATT&CK	T1657 Financial Theft, T1565.001 Stored Data Manipulation, T1684.001 Social Engineering: Impersonation
OWASP LLM 2025	LLM01 Prompt Injection, LLM06 Excessive Agency, LLM05 Improper Output Handling
OWASP Agentic 2026	ASI01 Agent Goal Hijack, ASI02 Tool Misuse, ASI03 Identity & Privilege Abuse, ASI07 Insecure Inter-Agent Communication, ASI09 Human-Agent Trust Exploitation
OWASP Smart Contract 2026	SC01 Access Control, SC02 Business Logic, SC05 Lack of Input Validation, SC06 Unchecked External Calls, SC08 Reentrancy : revue interne, **`docs-jury/rapport-securite.md`**

Métriques atteintes

Métrique	Valeur	Conditions et source
Factures payées sans intervention humaine	2 304 sur 2 400 (96 %)	Trimestre simulé de 65 jours ouvrés, coffre en mémoire ; campagne
Validations humaines	1,6 par jour ouvré, jusqu'à 4	Même campagne. 33 % des montants passent devant un humain
Placements excessifs proposés par l'agent	3 sur 6 refusés, 2,83 M€ visés	Même campagne ; 3 autres placements, totalisant 1,91 M€, ont été validés par un humain
Validations restées sans réponse	7 pendant 4 h	Refus à l'échéance ; factures représentées le lendemain dans la simulation
Compromission du rôle d'admission	915 677 € sur 1 016 807 € arrêtés (90 %)	19 fausses factures mises en validation humaine ; 11 sous le seuil payées, soit 101 130 € de perte résiduelle dans la simulation
Comité LLM sur AWS	39,8 s de délai médian sur 16 demandes	Avec une phrase seule, 2 voix sur 3 demandent une revue humaine ; campagne
Tests	332 Foundry, 199 hors chaîne, tous verts	**`docs-jury/tests.md`**

Limites connues

- La campagne trimestrielle est une simulation sur coffre en mémoire, avec volumes et montants choisis par l'équipe. Ses sorties figurent dans le PDF fourni ; le script **`campagne.ts`** et ses journaux bruts ne sont pas dans cette branche. Ces chiffres ne sont donc pas reproduits ici et ne mesurent pas un taux de fraude réel.
- Sur son jeu de test synthétique, la porte détecte 50 attaques sur 100 et bloque 4 demandes légitimes sur 100 (**`docs/mesures/bench-test.json`**). Le jeu a été écrit par un modèle, ses étiquettes n'ont pas été relues et il contient autant d'attaques que de demandes légitimes. En production, les faux positifs pèseraient davantage. Le taux de rattrapage du contrat sur ces 100 attaques n'est pas mesuré.
- Le contrat ne vérifie pas la vérité d'une facture : une fausse dette inscrite par le rôle d'admission serait payée. Un propriétaire ou un administrateur du L1 compromis sort du modèle.
- La perte du scénario interne suppose qu'un humain n'approuve aucune des 19 fausses factures mises en attente. S'il les approuve toutes, la perte peut atteindre 1 016 807 € dans cette simulation.
- Seuls les fonds détenus par le contrat sont protégés. Par défaut (**`VAULT_MODE=fake`**), la démo locale tourne sur un faux coffre.
- La pause d'un agent est appliquée hors chaîne, par la porte et par le relais. Le contrat sait la poser (**`pauseAgent`**), aucun service ne l'appelle.
- L'alerte est affichée et journalisée, elle n'est envoyée à personne. La décision humaine est déclarée, pas authentifiée.
- Le verdict du marché de vérification n'entre pas dans la décision du coffre : jonction conçue, non construite.
- L1 de test à un seul validateur, Fuji non testé, fonds de test sans valeur, revue de sécurité interne sans audit indépendant.